

## 100 Days of Azure DevOps

## Day 61 Handout — If the bouncer list is wrong, RBAC and Key Vault are cosplay

7 - Security, Compliance & Governance · Personal lab only · Educational content · Not a sales pitch

### Architecture A — tenant, user, app registration, service principal (four different objects)

| Object              | What it is                                                                      | Not the same as                                                                         |
|---------------------|---------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------|
| Tenant / directory  | The Entra boundary. Personal vs work — labs stay personal                       | A subscription. A sub lives in a tenant; they are not synonyms                          |
| User / group        | Human identities. Groups are how assignments should scale                       | An app registration. Apps are not users with a funny name                               |
| App registration    | Application object. Client ID (appld). Lives in the home tenant                 | An Azure DevOps service connection (Day 63). That is an ADO badge that may use this app |
| Service principal   | The instance of that app in a tenant (enterprise app). What RBAC is assigned to | The client secret. Secret is a credential on the app, not the SP itself                 |
| Client ID vs secret | ID is public-ish. Secret is a password. Cert/WIF later                          | Pasting a secret into YAML 'just for the lab'                                           |

### Architecture B — what to register today vs what to wait for

| Need                       | Default today                                                      | Wait                                                                |
|----------------------------|--------------------------------------------------------------------|---------------------------------------------------------------------|
| An app identity to look at | Portal: Entra ID → App registrations → New → day61-lab. Note appld | Client secret. Key Vault is Day 64; pipeline fetch is Day 65        |
| Redirect URI               | Skip for this lab (no user-login app)                              | Pretending every registration needs localhost redirect              |
| Which tenant               | Personal tenant only                                               | Work tenant 'because that's where Azure is' — that is how labs leak |
| Who is Owner on the app    | You. Not a random group from an employer directory                 | Subscription Owner on the app — that is Day 62's flamethrower       |
| Federation                 | Know WIF exists (Day 63)                                           | az ad app credential reset this afternoon                           |

### Architecture C — pitfalls that look like RBAC bugs and are actually the wrong directory

| Pitfall                           | What you see                                 | Fix                                                                  |
|-----------------------------------|----------------------------------------------|----------------------------------------------------------------------|
| Wrong tenant                      | App not listed; CLI talks to work directory  | az account show / portal directory switch. Labs = personal           |
| Secret in a screenshot            | Client secret on LinkedIn or in git          | Do not create a secret today. Note the appld only                    |
| Calling the app a user            | Trying to 'login as the registration'        | Users sign in; apps get tokens. Different objects                    |
| App vs service connection mash-up | One Portal blade expected to be the pipeline | Registration is Entra. Connection is Azure DevOps. Day 63 wires them |
| Work tenant screenshot            | Employer directory in the handout photo      | Personal tenant. Crop nothing from work                              |

## One-liner to remember

Entra ID is the bouncer list for Azure — if identity is wrong, every other control is cosplay. App registration is not a service connection, and a client ID is not a secret.

## Step-by-step lab (personal Azure / Azure DevOps only)

Personal Entra tenant only. Do not open an employer directory. Project azure-100-labs is later this week for connections.

- 1 Portal → Microsoft Entra ID (personal directory). Note tenant ID. az account show --query tenantId. If it is a work tenant, stop and switch.
- 2 Entra ID → App registrations → New registration → name day61-lab. Supported account types: this org only. Redirect URI: skip. Register.
- 3 Copy Application (client) ID and Directory (tenant) ID into docs/entra-day61.md. Not into azure-pipelines.yml.
- 4 Open Certificates & secrets. Do not create a client secret today. Read that secrets would live here, and that Day 63 prefers federated credentials instead.
- 5 Enterprise applications: find day61-lab — that object is the service principal. One sentence in the doc: registration vs SP vs (later) service connection.
- 6 No LinkedIn screenshot of secrets, tenant gossip, or work users. Optional CLI: az ad app create --display-name day61-lab --query appld -o tsv.

## Starter CLI — register, note appld, no secret

```
# Personal tenant only. Confirm first:
az account show --query "{sub:id, tenant:tenantId, user:user.name}" -o json
APP_ID=$(az ad app create --display-name day61-lab --query appId -o tsv)
az ad sp create --id $APP_ID --query id -o tsv
echo "Client ID (appId)=$APP_ID"
# Do NOT: az ad app credential reset - secret waits; WIF is Day 63
```

## Done checklist

- day61-lab exists in the personal tenant; tenant ID and appld recorded
- Can explain tenant vs user vs app registration vs service principal
- No client secret created; none in Git
- Knows a service connection is an Azure DevOps object (Day 63), not this blade

## Tomorrow — Day 62

RBAC deep dive — Owner is a flamethrower; scope is the verb